Relatorio Tecnico - Blindagem E2E e Substituicao de JWT

Data: 2026-11-04 | Commits: 6036402 (implementacao), 7a7e074 (sniffer), 89ae7cb (cobertura + mTLS real) | Suite: 217 testes passando | Convencao: medido x contrato x nao avaliado

1. Veredicto

O mecanismo esta provado; a arquitetura como malha de producao nao esta - e isso e o correto neste estagio. Provado em teste dinamico real: todo request /v1/ e decifrado antes da regra de negocio; toda response sai cifrada - inclusive erros 4xx/5xx; o fio so carrega quadros 0xE2; identidade vem de certificado de cliente em handshake TLS 1.3 real; broker e storage so transportam ciphertext. Contrato (config verificada estaticamente): topologia do compose, nginx.conf, URLs TLS internas, E2E_OBRIGATORIO=1. Nao avaliado: prova de NIC na rede interna com conteineres reais, latencia, rotacao de chaves, transito A<->B entre dois nos.

2. Esclarecimento tecnico aplicado

'Hash ponta a ponta' literal nao existe: hash e irreversivel e o receptor nao recupera o dado. A propriedade pedida (claro so em memoria, ciphertext na rede) exige cifra autenticada (AEAD). Implementado ChaCha20-Poly1305 (RFC 8439): confidencialidade + integridade + deteccao de adulteracao num selo. SHA-256 segue na integridade de documento da trilha.

3. Remocao completa do JWT

Artefato	Acao
app/deps.py	reescrito - jwt.decode/PyJWT/JWT_PUBLIC_KEY fora; identidade = X-Cliente-Orgao do terminador mTLS
tests/jwthelper	

Motivo: Bearer JWT vive no cliente e e exfiltravel (XSS/localStorage); certificado de cliente fica no SO/HSM do orgao. A API confia no header porque o compose garante que so o nginx alcanca a rede interna.

4. Nucleo criptografico - app/crypto_e2e.py

- Quadro: 0xE2 | nonce 12B | len 4B | ciphertext+tag 16B
- AAD = indice do quadro: reordenacao/supressao quebra o selo
- Terminador 0xE2+16x00: truncamento de stream detectavel
- Streaming real - bloco a bloco, sem materializar em RAM
- Chave via E2E_CHAVE (hex 32B, Vault em runtime); ausente = bypass de dev; malformada = ErroCripto (fail closed)

5. Os tres interceptadores

Fronteira	Codigo	Comportamento provado
HTTP	app/middleware_e2e.py (ASGI)	decifra body antes do roteador; cifra response quadro a quadro; plaintext em /v1/ = 415; selo invalido = 400
Broker		

6. Configuracao - deploy/

- nginx.conf: TLS 1.3 apenas, ssl_verify_client on, CA dos pares, CN do ssl_client_s_dn -> X-Cliente-Orgao, Authorization zerado no proxy, buffering off (streaming)
- compose.yaml: nginx monta conf+certs :ro; api com E2E_OBRIGATORIO=1 + E2E_CHAVE passthrough do Vault
- gerar_certs_mtls.py: CA dev + certs por orgao (CN=id) - dev only; producao usa PKI de cada instituicao

7. O que foi medido (provas executadas)

#	Prova	Resultado
1	Fio so carrega ciphertext (socket real, cada byte)	sentinela PII e caso_cnj ausentes de 100% do fio; dois lados = quadros 0xE2
2	Contro	

8. Limitacoes honestas (desenho, nao bugs)

- Chave simetrica por par de nos: quem vaza a chave decifra E forja trafego nos dois sentidos; sem forward secrecy (TLS de transporte mitiga o hop, a camada E2E nao tem PFS)
- AEAD nao impede replay de envelope integro - defesa e a idempotency_key do negocio; timestamp+janela e o endurecimento natural pendente
- X-Cliente-Orgao e confianca de perimetro: quem ja esta na interna pode forjar o header (ameaca interna fora do modelo de borda)
- XSS mitigado, nao eliminado: a credencial deixa de ser copiavel, mas um XSS ainda pode disparar requests autenticados pelo navegador
- abrir materializa o corpo do request: ok p/ JSON de controle; upload multipart grande atravessa num quadro (stream de ingresso e melhoria futura)

9. Nao avaliado

- NIC/tcpdump na rede interna com o compose de pe - bytes do socket provam o payload; a malha conteiner-a-conteiner nao
- TLS dos clientes internos (amqps, sslmode, https S3) - contrato de URL, nenhum handshake medido
- nginx.conf executada - a primitiva foi provada; a config em si e assert estatico
- Transito A<->B entre nos reais - falta o lado emissor do envelope E2E no repo
- Latencia/overhead da cifragem - nao medida
- Rotacao/revogacao de E2E_CHAVE - depende do Vault (passo 3) + decisao juridica de reidentificacao

10. Conclusao

Camada de dados: invariantes mantidas e reforcadas (binario nunca em envelope/broker/DB; agora tambem nunca legivel em repouso nem no fio) - provado com medicao. Camada de transporte E2E: mecanismo provado em toda a

superficie da API; falta a malha (no<->no, servicos internos, NIC). Identidade: mecanismo provado em handshake real; falta executar o nginx com certs de producao. Chamar 'arquitetura validada' so depois do tcpdump na interna, dos handshakes internos medidos e do round-trip A<->B.